that you'll develop, and you can relate each of them to a STRIDE threat (chapter 1) that they prevent:

- ***Rate-limiting*** is used to prevent users overwhelming your API with requests, limiting denial of service threats.
- ***Encryption*** ensures that data is kept confidential when sent to or from the API and when stored on disk, preventing information disclosure. Modern encryption also prevents data being tampered with.
- ***Authentication*** makes sure that users are who they say they are, preventing spoofing. This is essential for accountability, but also a foundation for other security controls.
- ***Audit logging*** is the basis for accountability, to prevent repudiation threats.
- Finally, you'll apply ***access control*** to preserve confidentiality and integrity, preventing information disclosure, tampering and elevation of privilege attacks.

An important detail, shown in figure 3.1, is that only rate-limiting and access control directly reject requests. A failure in authentication does not immediately cause a request to fail, but a later access control decision may reject a request if it is not authenticated. This is important because we want to ensure that even failed requests are logged, which they would not be if the authentication process immediately rejected unauthenticated requests.